

Beam & Oracle Providers PR Audit Report

Table of Contents

1. Executive Summary	4
About LoopScale	4
Audit Summary	4
Overall Security Posture	4
Launch Recommendations	5
Audit Scope	5
2. Assumptions and Considerations	6
Project & Protocol Assumptions	6
Trust Assumptions	6
3. Severity Definitions	7
Impact	7
Likelihood	7
Severity Classification Matrix	7
4. Findings	9
M01: BEAM V3 stores full bid/ask spread as uncertainty, but LoopScale uses it as one-sided price bias	9
L01: LP price calculation assume SY decimals are always the same as underlying decimals which could break the accounting	13
L02: First-depositor mitigation still leaves a deposit DoS when lp_to_mint == 0	15
L03: SDK builds the wrong remaining account layout for BEAM Chainlink writes	17
L04: BEAM accepts expired Chainlink reports and LoopScale may still use them when max_age is looser than report expiry	20
L05: Hardcoded 18-decimal assumption in Chainlink V3 price parsing will produce incorrect prices for 8-decimal feeds	24
5. Enhancement Opportunities	26
E01: Rename underlying_balance and underlying_token_value_per_lp_token to reflect SY token semantics	26
E02: parse_chainlink_bigint_18_decimals_to_u64 function name does not reflect actual behavior	27

About Us	28
About Adevar Labs	28
Audit Methodology	28
Confidentiality Notice	29
Legal Disclaimer	29

1. Executive Summary

About Loopscale

Loopscale is an order book-based lending platform on Solana. This audit was focused on the BEAM program, a newly developed feature acting as an oracle aggregation tool integrating directly with Loopscale. Its goal is to securely cache asset prices from Chainlink using permissionless, on-chain verified updates. Loopscale consumes these prices while managing staleness, uncertainty bounds, and real-time fallbacks. The update also featured new oracle adapters or modified ones.

Audit Summary

The table below summarizes identified vulnerabilities by risk level and remediation status.

Risk Level	Count	Fixed	Acknowledged
Critical	0	0	0
High	0	0	0
Medium	1	1	0
Low	5	5	0

Enhancement opportunities: 2

Overall Security Posture

The Loopscale team demonstrated solid expertise in Solana development with their implementation of the BEAM oracle aggregation program and oracle providers. The team showed good understanding of Chainlink integration patterns and oracle security considerations. The identified issues primarily relate to edge cases in price calculations and integration mismatches rather than fundamental architectural flaws.

After Fix Review Summary

The fix review confirmed successful resolution of both Medium and Low severity findings. The Loopscale team's implementation of the enhancement opportunities further demonstrates their commitment to code quality and security best practices.

Before Fix Review Summary

The audit identified 1 Medium severity issues related to BEAM V3 uncertainty calculation discrepancies, as well as 5 Low severity issues, including first-depositor DoS vulnerability, SDK account layout mismatches for BEAM Chainlink writes, LP price calculation decimal assumptions, expired Chainlink report acceptance, and hardcoded decimal assumptions for 8-decimal feeds. Additionally, 2 enhancement opportunities were identified to improve variable naming clarity and function documentation accuracy.

Launch Recommendations

After Fix Review Summary

All identified security issues have been successfully addressed. The team implemented fixes for the LP price calculation decimal handling, first-depositor protection mechanisms, SDK account layout corrections, and BEAM V3 uncertainty calculations. The implementation of recommended variable naming improvements and function documentation updates demonstrates the team's attention to code quality and maintainability.

Before Fix Review Summary

I. Mandatory before launch:

- Fix the LP price calculation to use correct SY token decimals instead of underlying decimals to prevent accounting errors
- Implement proper first-depositor protection by minting initial shares to a burn address during vault initialization
- Correct the SDK helper to build the proper 5-account layout for BEAM Chainlink writes
- Address the BEAM V3 uncertainty calculation to use one-sided deviation instead of full spread

II. Strongly recommended:

- Implement expiry validation for Chainlink reports in BEAM before caching prices
- Add decimal precision field to BeamPricingMetadata to support both 8 and 18-decimal Chainlink feeds
- Rename variables in Exponent LP pricing to reflect SY token semantics for better code clarity
- Update function names to accurately reflect their actual behavior

Audit Scope

The audit scope was performed on the diff between 'Base Commit Hash' and 'Before-Fix Review Commit Hash'.

All remediation pull requests have landed on 'After-Fix Review Commit Hash'.

- **Repository:** <https://github.com/LoopscaleLabs/loopscale-program-library>
- **Before-Fix Review Commit Hash:** [0239de54e73598d179725b7a0a19929e2bb7efb0](#)
- **After-Fix Review Commit Hash:** [ffe3ec664c0910bb97550f8c630488101e6fa162](#)
- **Base Commit Hash:** [7cd382cdd9b77b47a4ed024313ce26d2100439b7](#)
- **Files/Modules in Scope:**
 - All changes in [programs](#) and [programs-utils](#)

2. Assumptions and Considerations

Project & Protocol Assumptions

- The `get_exponent_lp_token_price_with_quantity` function uses a linear approximation to compute the PT exchange rate which differs from actual exchange rate computed by Exponent.
- The `max_age` and `max_uncertainty` parameters in asset configurations are set to reasonable values appropriate for each asset's volatility and update frequency.

Trust Assumptions

- The protocol trusts Chainlink Data Streams (V3 and V7) to provide accurate, timely, and correctly signed price data via the on-chain verifier program.
- The protocol trusts the Chainlink verifier program to correctly validate DON signatures and return only authenticated report payloads, including proper validation of the `report_config` account which BEAM does not constrain.

3. Severity Definitions

Each issue identified in this report is assigned a severity level based on two dimensions: **Impact** and **Likelihood**. These dimensions help project our team's understanding of both the potential consequences of a vulnerability and how likely a vulnerability is to be discovered and exploited in the real world.

Note: Enhancements represent non-blocking improvements—typically usability, observability, or defense-in-depth tweaks that do not pose an immediate asset risk but would improve the product's reliability and/or user experience if implemented.

Impact

Impact reflects the potential consequences of the issue—particularly on **project funds, user funds**, and the **availability or integrity** of the protocol.

- **High Impact:** Successful exploitation could result in a complete loss of user or protocol funds, disruption of core protocol functionality, or permanent loss of control over critical components.
- **Medium Impact:** Exploitation could cause significant disruption or partial loss of funds, but not a total compromise. May impact some users or non-core functionality.
- **Low Impact:** The issue has minor or negligible consequences. It may affect edge cases, expose metadata, or degrade performance slightly without putting funds or core logic at serious risk.

Likelihood

Likelihood reflects how easy a vulnerability is to discover and exploit by an attacker, as well as how economically attractive the exploit is to an attacker.

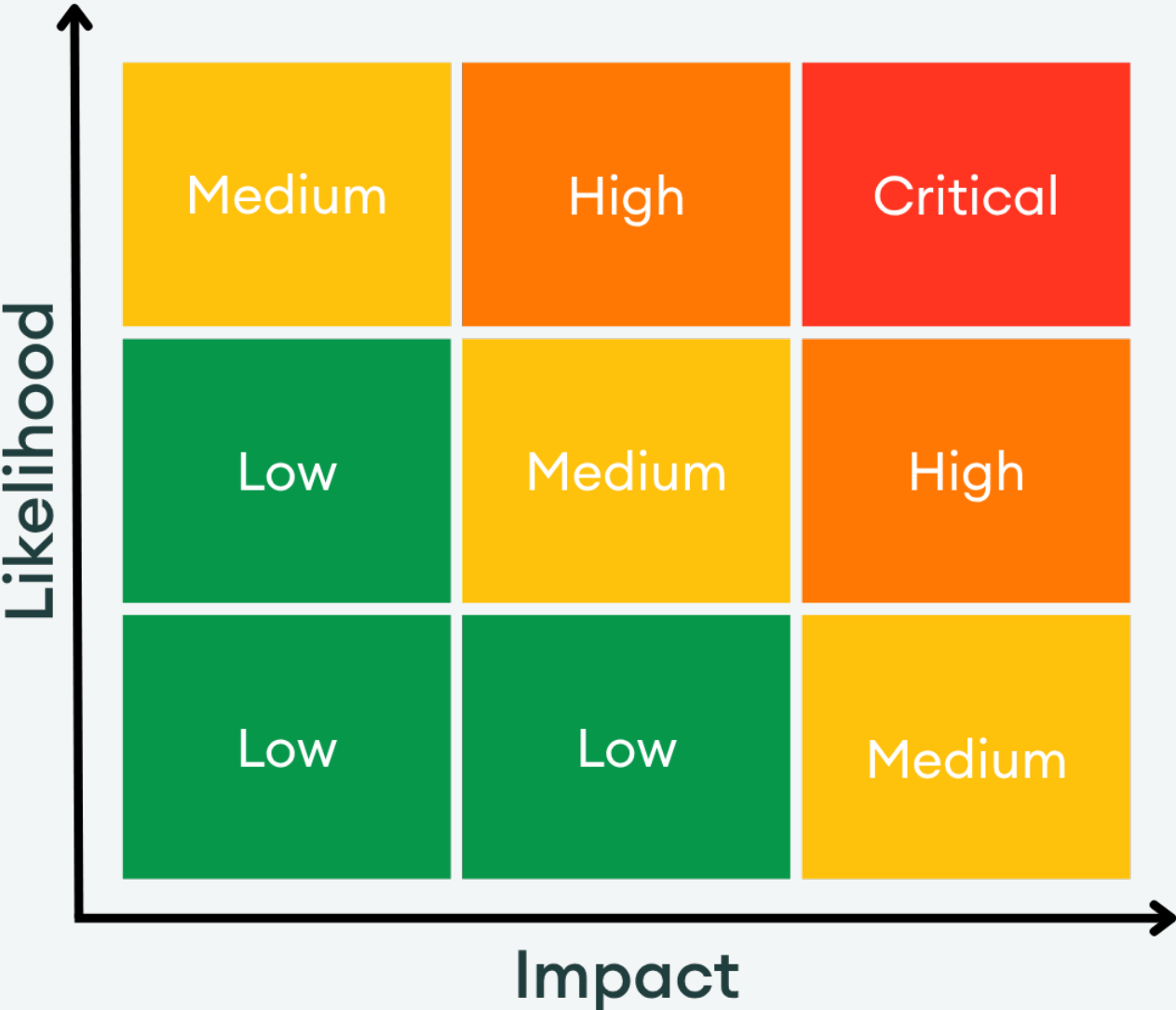
- **High Likelihood:** The vulnerability is trivially exploitable. This means it can be exploited by a wide range of actors without privileged access rights, with minimal capital requirements and low financial risks.
- **Medium Likelihood:** This type of vulnerability can be found and exploited with moderate effort. It might require a significant capital investment, but with manageable financial risk.
- **Low Likelihood:** Exploitation of these vulnerabilities is often technically unfeasible or requires highly specialized conditions. They may require extraordinary effort or a significant financial risk for an attacker, with a high chance of failure and minimal potential return.

Severity Classification Matrix

By combining **Impact** and **Likelihood**, we assign a severity level using the matrix below:

- **Critical:** High impact + high likelihood (e.g. a bug that could allow anyone to drain a substantial amount of protocol funds with minimal effort)
- **High:** High impact with medium likelihood, or medium impact with high likelihood
- **Medium:** Moderate impact and/or discoverability
- **Low:** Minimal impact or unlikely to be exploited

This structured approach helps teams prioritize fixes and mitigate the most dangerous threats first.



Severity Matrix

About Us

About Adevar Labs

Adevar Labs is a boutique blockchain security firm specializing in web3 audits.

Built by a mix of experienced professionals in traditional enterprise and crypto natives who have contributed to some of the most critical projects in blockchain infrastructure.

Our team's background spans companies like Bitdefender, Asymmetric Research, Quantstamp, Chainproof, and Juicebox, and includes experience securing smart contracts, bridges, and L1 and L2 protocols across ecosystems like Solana, Ethereum, Polkadot, Cosmos, and MultiversX.

With over 100 audits completed and a portfolio that includes custom fuzzers, exploit modeling, and runtime testing frameworks, Adevar Labs brings both depth and precision to every engagement.

Our auditors have discovered critical vulnerabilities, built high-impact tooling, and placed in top positions in premier audit competitions including Code4rena and Sherlock.

Team members hold distinctions such as PhDs in software protection, and key roles at Fortune 500 companies, and leadership of flagship conferences like ETH Bucharest.

With team members having publications with over 1,100 academic citations and trusted by projects securing over \$500M in on-chain value, Adevar Labs blends elite technical rigor with real-world security impact.

We also collaborate with some of the best independent security researchers in the web3 space.

Projects may optionally request specific contributors to be part of their audit.

Audit Methodology

Our audit methodology is specialized to provide thorough security assessments of Solana programs. We focus explicitly on rigorous manual analysis, detailed threat modeling, and careful validation of implemented fixes to ensure your programs operate securely and as intended.

1. Program Context and Architecture Analysis

Our auditors begin by deeply examining your Solana program's documentation, intended functionality, and account design. We meticulously map out program interactions, instruction processing flows, and state management logic. Special attention is given to understanding how your program interfaces with critical Solana system programs, such as the SPL Token Program, Stake Program, and System Program. Last but not least we check external integrations with other Solana projects and verify if the inputs and return values are handled properly.

2. Threat Modeling

We conduct targeted threat modeling tailored specifically for Solana's execution environment. We carefully define attacker capabilities and identify potential vulnerabilities that may arise from Solana-specific issues, including but not limited to:

- Unauthorized account data manipulation
- Improper ownership or signer verification
- Misuse of Program-Derived Addresses (PDAs)

- Incorrect use of Cross-Program Invocations (CPI)
- Failure to adequately handle account privileges or account states
- Risks stemming from rent-exemption and account initialization logic

3. In-depth Manual Security Review

Our experienced auditors perform an extensive manual security review of your Rust-based Solana programs. This involves a comprehensive line-by-line inspection of source code, focusing on common Solana vulnerabilities including, but not limited to:

- Missing or insufficient ownership checks
- Inadequate signer checks
- Incorrect handling of CPI calls and invocation privileges
- Arithmetic and integer overflow or underflow errors
- Unsafe deserialization and serialization of account data structures
- Improper token transfers and SPL-token logic issues
- Logic flaws in financial operations or state transitions
- Edge-case handling in instruction input validation
- Potential denial-of-service vectors related to transaction execution and account handling

During this stage, we clearly document any discovered vulnerabilities, including detailed descriptions, precise severity ratings, and recommendations for secure implementation. In situations where it is not clear how the vulnerability might be exploited we may also include a detailed proof-of-concept exploit including code snippets and instructions on how the exploit could be performed.

4. Detailed Fix Review and Validation

After the initial audit and your team's subsequent remediation efforts, we perform a comprehensive fix review to ensure the vulnerabilities identified have been effectively resolved.

We verify each fix individually, confirming that:

- Corrections effectively eliminate the security risks
- Changes do not inadvertently introduce new vulnerabilities or regressions
- The fixes align closely with Solana best practices and secure coding guidelines

Our detailed validation ensures that security improvements are robust, complete, and aligned with best practices specific to the Solana development ecosystem.

Confidentiality Notice

This report, including its content, data, and underlying methodologies, is subject to the confidentiality and feedback provisions in your agreement with Adevar Labs. These materials are not to be disclosed, extracted, copied, or distributed except to the extent expressly authorized by Adevar Labs.

Legal Disclaimer

The review and this report are provided by Adevar Labs on an as-is, where-is, and as-available basis. To the fullest extent permitted by law, Adevar Labs disclaims all warranties, expressed or implied, in

connection with this report, its content, and your use thereof, including, without limitation, the implied warranties of merchantability, fitness for a particular purpose, and non-infringement.

You agree that access to and/or use of the report and other results of the review, including any associated services, products, protocols, platforms, content, and materials, will be at your sole risk.

FOR AVOIDANCE OF DOUBT, THE REPORT, ITS CONTENT, ACCESS, AND/OR USAGE THEREOF, INCLUDING ANY ASSOCIATED SERVICES OR MATERIALS, SHALL NOT BE CONSIDERED OR RELIED UPON AS ANY FORM OF FINANCIAL, INVESTMENT, TAX, LEGAL, REGULATORY, OR OTHER ADVICE. This report is based on the scope of materials and documentation provided for a limited review at the time provided.

You acknowledge that blockchain technology remains under development and is subject to unknown risks and flaws. Adevar Labs does not warrant, endorse, guarantee, or assume responsibility for any product or service advertised or offered by a third party, or any open-source or third-party software, code, libraries, materials, or information accessible through the report. As with the purchase or use of a product or service in any environment, you should use your best judgment and exercise caution where appropriate.